

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

«Организационное и правовое обеспечение информационной безопасности»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №3

«Организационная защита информации»

Выполнили:

Бардышев Артём Антонович,
студент группы N3346



(подпись)

Проверил:

Евглевская Н.В.,
к.т.н., доцент, ФБИТ

(отметка о выполнении)

(подпись)

Санкт-Петербург

2026 г.

СОДЕРЖАНИЕ

Введение	3
1 Теоретические основы организационной защиты информации	4
1.1 Понятие и место организационной защиты в системе обеспечения ИБ	4
1.2 Модели организационной структуры управления ИБ	5
1.2.1 Децентрализованная модель	5
1.2.2 Централизованная модель	5
1.2.3 Гибридная модель	6
1.2.4 Рекомендации по выбору модели	6
1.3 Жизненный цикл управления доступом	7
Заключение	10
Список использованных источников	11

ВВЕДЕНИЕ

Цель работы – Изучить теоретические и практические аспекты организационной защиты информации, выявить роль человеческого фактора в обеспечении информационной безопасности, разработать комплекс организационно-распорядительных документов и программу повышения осведомленности персонала.

Задачи работы

Раскрыть сущность организационной защиты информации и ее место в общей системе обеспечения ИБ.

Изучить модели организационной структуры управления информационной безопасностью.

Проанализировать жизненный цикл управления доступом.

Выявить основные риски, связанные с человеческим фактором, и классифицировать инциденты.

Разработать структуру Политики информационной безопасности организации.

Создать годовую программу повышения осведомленности персонала с элементами геймификации.

Подготовить заключение и список использованных источников.

1 ТЕОРЕТИЧЕСКИЕ ОСНОВЫ ОРГАНИЗАЦИОННОЙ ЗАЩИТЫ ИНФОРМАЦИИ

1.1 Понятие и место организационной защиты в системе обеспечения ИБ

Организационная защита информации — это совокупность управленческих, административных и правовых мер, направленных на регламентацию действий персонала, организацию процессов обработки информации, управление доступом, планирование действий в чрезвычайных ситуациях и обеспечение дисциплины в области информационной безопасности.

Организационная защита является фундаментом системы обеспечения информационной безопасности по ряду причин:

Первичность по отношению к техническим средствам. Технические средства защиты (межсетевые экраны, антивирусы, системы обнаружения вторжений) реализуют требования, которые изначально закладываются на организационном уровне. Без четко определенных правил доступа, регламентов работы и распределения ответственности технические средства теряют свою эффективность.

Охват всех этапов жизненного цикла информации. Организационные меры сопровождают информацию на всех этапах — от создания (определение грифов секретности, категорий доступа) до уничтожения (утверждение актов уничтожения, контроль вывода носителей из эксплуатации).

Регулирование человеческого фактора. По статистике, от 60% до 80% инцидентов информационной безопасности связаны с действиями (ошибочными или преднамеренными) персонала. Организационные меры направлены на минимизацию этих рисков через обучение, контроль, создание культуры безопасности.

Юридическая основа ответственности. Организационные документы (политики, регламенты, приказы) создают правовую базу для привлечения сотрудников к дисциплинарной, материальной или административной ответственности за нарушения.

1.2 Модели организационной структуры управления ИБ

Выбор организационной структуры службы информационной безопасности зависит от масштаба организации, отраслевой принадлежности, уровня зрелости процессов ИБ и требований регуляторов. В практике сложились три основные модели.

1.2.1 Децентрализованная модель

Характеристика: подразделения информационной безопасности создаются в каждой бизнес-единице или филиале, подчиняясь локальным руководителям. Координация между подразделениями осуществляется через совещательные органы или отсутствует.

Преимущества:

- быстрое реагирование на локальные потребности и угрозы;
- глубокое понимание специфики бизнес-процессов каждого подразделения;
- гибкость в распределении ресурсов.

Недостатки:

- отсутствие единых стандартов и политик (каждое подразделение действует по-своему);

- дублирование функций и неэффективное использование ресурсов;

- сложность контроля и аудита;

- риск возникновения конфликтов между локальными политиками.

Применение: может использоваться в крупных холдингах с высокой степенью автономии бизнес-единиц, где требования к ИБ значительно различаются. Однако даже в таких структурах обычно создается центральный орган для выработки единых стандартов.

1.2.2 Централизованная модель

Характеристика: единый департамент (управление, отдел) информационной безопасности, подчиняющийся непосредственно высшему руководству организации (генеральному директору, совету директоров). Все функции ИБ сосредоточены в этом подразделении.

Преимущества:

- единая политика и стандарты для всей организации;
- эффективное использование ресурсов и специалистов;
- централизованный контроль и мониторинг;
- единая точка ответственности.

Недостатки:

возможное отставание от потребностей бизнес-подразделений;

бюрократизация процессов;

сложность учета специфики различных направлений деятельности.

Применение: оптимальна для средних и крупных организаций с однородной структурой, а также для организаций, подпадающих под жесткое регулирование (кредитно-финансовая сфера, объекты КИИ, государственные учреждения).

1.2.3 Гибридная модель

Характеристика: сочетание централизованного управления с наличием ИБ-кураторов в бизнес-подразделениях. Центральный департамент ИБ разрабатывает политики, стандарты, осуществляет контроль и управляет централизованными средствами защиты. Кураторы в подразделениях обеспечивают адаптацию общих требований к специфике, осуществляют локальный контроль и являются «мостом» между ИБ и бизнесом.

Преимущества:

сочетание единых стандартов с учетом локальной специфики;

оперативное доведение требований до бизнес-подразделений;

более высокая вовлеченность бизнеса в вопросы ИБ;

эффективное распределение функций.

Недостатки:

сложность управления и координации;

риск дублирования функций и конфликтов компетенций;

более высокие затраты на персонал.

Применение: наиболее эффективна для крупных организаций с разнородной структурой (промышленные холдинги, крупные ритейлеры, транснациональные компании), а также для организаций, находящихся на высоком уровне зрелости ИБ-процессов.

1.2.4 Рекомендации по выбору модели

Выбор модели организационной структуры ИБ должен основываться на следующих факторах:

размер организации и количество сотрудников;

количество и разнородность бизнес-направлений;

уровень регуляторных требований (наличие лицензий ФСТЭК, ФСБ, требования ЦБ РФ);

бюджет на ИБ;

текущий уровень зрелости ИБ-процессов.

Для большинства организаций оптимальной является гибридная модель, которая позволяет сохранить централизованный контроль при обеспечении необходимой гибкости. Для малых организаций (до 100–150 сотрудников) может быть достаточной централизованная модель с выделенным руководителем ИБ и небольшим отделом.

1.3 Жизненный цикл управления доступом

Управление доступом является ключевым организационным процессом, обеспечивающим реализацию принципа наименьших привилегий и предотвращение несанкционированного доступа. Жизненный цикл управления доступом включает пять последовательных этапов.

Этап 1. Инициирование доступа

На этом этапе возникает потребность в предоставлении доступа новому сотруднику (или изменении прав существующего) в связи с:

приемом на работу;

переводом на новую должность;

расширением функциональных обязанностей;

участием в новом проекте;

необходимостью доступа подрядчиков или внешних специалистов.

Процедура инициирования включает:

заполнение заявки на доступ (в бумажной или электронной форме);

указание основания для доступа (должностная инструкция, приказ о приеме, договор с подрядчиком);

определение необходимых ресурсов и требуемого уровня доступа (чтение, запись, модерация, административные права).

Этап 2. Согласование доступа

Заявка на доступ подлежит согласованию несколькими сторонами

В зависимости от уровня доступа и критичности системы могут применяться различные уровни согласования:

стандартный доступ (пользовательские права в корпоративных системах);

согласование руководителя подразделения и ИБ;

привилегированный доступ (административные права, доступ к СУБД, конфигурационным файлам): дополнительное согласование с руководителем ИБ или техническим директором;

доступ к особо критичным системам (АСУ ТП, платежные системы, системы управления базами данных с персональными данными): согласование на уровне руководства организации.

Этап 3. Предоставление доступа

После получения всех согласований заявка направляется на исполнение. В зависимости от типа доступа исполнение могут осуществлять:

администраторы информационных систем (для доступа к прикладному ПО);

администраторы сетей и серверов (для доступа к инфраструктурным ресурсам);

служба ИБ (для доступа к средствам защиты информации, VPN).

Важным требованием является немедленная фиксация факта предоставления доступа в журнале учета с указанием даты, времени и лица, предоставившего доступ. При предоставлении доступа должна быть обеспечена возможность последующего аудита: все действия пользователя должны логироваться и привязываться к его учетной записи.

Этап 4. Мониторинг и периодический пересмотр доступа

Предоставленный доступ не должен быть бессрочным. Организационно устанавливаются процедуры регулярного пересмотра прав доступа:

Плановый пересмотр: не реже одного раза в квартал (для привилегированных учетных записей — ежемесячно) проводится ресертификация (recertification) прав доступа. Владелец ресурса подтверждает, что предоставленные права по-прежнему необходимы.

Внеплановый пересмотр: при изменении должностных обязанностей, структурных перестановках, выявлении нарушений.

Результаты пересмотра оформляются актом, в котором фиксируются:

перечень учетных записей, права которых были подтверждены;

перечень учетных записей, права которых были изменены (с указанием причин);

перечень учетных записей, которые были заблокированы (уволенные сотрудники, неиспользуемые учетные записи).

Этап 5. Завершение доступа (отзыв прав)

Завершение доступа происходит в следующих случаях:

увольнение сотрудника;

перевод на другую должность (изменение функционала);

окончание срока действия договора с подрядчиком;

выявление нарушений, повлекших временное или постоянное отстранение.

Критически важным требованием является немедленный отзыв доступа при увольнении. Организационно это обеспечивается:

включением процедуры отзыва доступа в регламент увольнения;

установлением ответственности руководителя подразделения за своевременное информирование служб;

автоматической блокировкой учетных записей при увольнении в интегрированной системе управления персоналом.

Отзыв доступа должен охватывать все информационные системы, к которым имел доступ сотрудник: доменная учетная запись, корпоративная почта, VPN, облачные сервисы, пропускная система (СКУД), физические ключи от помещений.

ЗАКЛЮЧЕНИЕ

В ходе выполнения лабораторной работы была достигнута поставленная цель — изучены теоретические и практические аспекты организационной защиты информации, выявлена роль человеческого фактора в обеспечении информационной безопасности, разработан комплекс организационно-распорядительных документов и программа повышения осведомленности персонала.

В теоретической части работы было установлено, что организационная защита информации является фундаментом всей системы обеспечения информационной безопасности. Она выполняет первичную функцию по отношению к техническим средствам, охватывает все этапы жизненного цикла информации, регулирует человеческий фактор и создает юридическую основу для привлечения к ответственности. Без четко определенных организационных механизмов любые технические средства защиты (межсетевые экраны, антивирусы, системы обнаружения вторжений) теряют свою эффективность.

Рассмотрены три основные модели организационной структуры управления информационной безопасностью: децентрализованная, централизованная и гибридная. Проведенный анализ показал, что выбор модели зависит от масштаба организации, отраслевой принадлежности, уровня регуляторных требований и степени зрелости ИБ-процессов. Для большинства организаций оптимальной является гибридная модель, сочетающая единые стандарты с учетом локальной специфики бизнес-подразделений.

Детально изучен жизненный цикл управления доступом, включающий пять последовательных этапов: инициирование доступа, согласование, предоставление, мониторинг и периодический пересмотр, завершение доступа (отзыв прав). Установлено, что критически важным требованием является немедленный отзыв доступа при увольнении сотрудника, что должно быть закреплено организационно в регламентах и кадровых процедурах.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1) Трудовой кодекс Российской Федерации : Федеральный закон от 30.12.2001 № 197-ФЗ (ред. от 28.02.2026). – Текст : электронный // Официальный интернет-портал правовой информации. – URL: <http://pravo.gov.ru> (дата обращения: 25.03.2026).

2) Об информации, информационных технологиях и о защите информации : Федеральный закон от 27.07.2006 № 149-ФЗ (ред. от 26.12.2025). – Текст : электронный // Официальный интернет-портал правовой информации. – URL: <http://pravo.gov.ru> (дата обращения: 25.03.2026).

3) О персональных данных : Федеральный закон от 27.07.2006 № 152-ФЗ (ред. от 25.12.2025). – Текст : электронный // Официальный интернет-портал правовой информации. – URL: <http://pravo.gov.ru> (дата обращения: 25.03.2026).

4) О коммерческой тайне : Федеральный закон от 29.07.2004 № 98-ФЗ (ред. от 25.12.2025). – Текст : электронный // Официальный интернет-портал правовой информации. – URL: <http://pravo.gov.ru> (дата обращения: 25.03.2026).

5) Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных : Постановление Правительства РФ от 01.11.2012 № 1119 (ред. от 15.09.2025). – Текст : электронный // Официальный интернет-портал правовой информации. – URL: <http://pravo.gov.ru> (дата обращения: 25.03.2026).

6) Об утверждении Положения о системе управления охраной труда : Приказ Минтруда России от 29.10.2021 № 776н (ред. от 20.12.2025). – Текст : электронный // Официальный интернет-портал правовой информации. – URL: <http://pravo.gov.ru> (дата обращения: 25.03.2026).